

Cybersecurity Daily Newsletter

Vol. 004 | 2026-08-27 09:00 WIB

Top 5 Highlights

- ISC Stormcast For Thursday, August 27th, 2026
<https://isc.sans.edu/podcastdetail/10070>, (Thu, Aug 27th)
- FBI seizes hacking tools it says China used to attack NASA, DOE, US Senate and other critical networks
- Nimbus Manticore expands infrastructure and malware arsenal
- Carhartt data breach claims inflated by synthetic data, analysis finds
- Ubiquiti patches 3 critical remote code execution vulnerabilities

Threat Intelligence (10)

01. ISC Stormcast For Thursday, August 27th, 2026

<https://isc.sans.edu/podcastdetail/10070>, (Thu, Aug 27th)

ISC Stormcast For Thursday, August 27th, 2026 <https://isc.sans.edu/podcastdetail/10070>, (Thu, Aug 27th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33286>

02. FBI seizes hacking tools it says China used to attack NASA, DOE, US Senate and other critical networks

Beijing's botnets busted.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/08/27/fbi-seizes-hacking-tools-it-says-china-used-to-attack-nasa-doe-us-senate-and-other-critical-networks/5292742>

03. Nimbus Manticore expands infrastructure and malware arsenal

Nimbus Manticore, associated with the Tortoiseshell (Imperial Kitten) cluster, has been observed using an SSH-based tunneling utility and a C++ backdoor similar to its existing TWOSTROKE implant.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/nimbus-manticore-expands-infrastructure-and-malware-arsenal>

04. Dark Caracal Adds New Malware to Cyber Espionage Arsenal

GoCaracal is a new modular malware framework that broadens Dark Caracal's capabilities to steal data and maintain access to victims.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/dark-caracal-adds-new-malware-cyber-espionage-arsenal>

05. Android Malware Hijacks Update System for Car Head Units

Threat actors behind a notorious click-fraud botnet have set their sights on vehicle infotainment modules and are abusing legitimate functionality to spread infections.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/android-malware-hijacks-update-system-car-head-units>

06. Nimbus Manticore Expands Toolset With TWOSTROKE-Like Backdoor and SSH Tunneler

Cybersecurity researchers have discovered additional infrastructure and previously undocumented malware associated with Nimbus Manticore, an Iranian state-sponsored hacking group affiliated with the Islamic Revolutionary Guard Corps (IRGC). Group-IB, in a new analysis published today, described the cyber espionage actor as among the most active Iranian APT...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/08/nimbus-manticore-expands-toolset-with.html>

07. AI Speeds Up Malware Development, Not Its Success Rate: Analysis

Palo Alto Networks Unit 42 analyzed 405 AI-linked malware samples and found only 12 reached production endpoints. The post AI Speeds Up Malware Development, Not Its Success Rate: Analysis appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.securityweek.com/ai-speeds-up-malware-development-not-its-success-rate-analysis/>

08. Tortoiseshell Expands Malware Toolset With New Backdoor, SSH Tunnel

Group-IB uncovered new Tortoiseshell infrastructure, including a backdoor and SSH tunneling tool

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/tortoiseshell-new-backdoor-ssh/>

09. NovaCookies Campaigns Abuse Genuine Docusign Notifications to Steal Microsoft 365 Sessions

Cybersecurity researchers have disclosed details of a new adversary-in-the-middle (AitM) phishing toolkit called NovaCookies that's used as a proxy to redirect Microsoft 365 sign-ins, while capturing authenticated sessions in the process. In a report shared with The Hacker News ahead of publication, Island characterized the \$320/month service as a subscript...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/08/novacookies-campaigns-abuse-genuine.html>

10. AnonymouSKIT phishing-as-a-service uses AI voice calls to steal iPhone passcodes

A phishing-as-a-service (PhaaS) platform called AnonymouSKIT is automating the theft of Apple ID credentials needed to remove Activation Lock from stolen iPhones, SOCRadar found. "By leveraging a critical flaw - the use of bare relative paths - the investigation unraveled a reseller supply chain of 506 domains and 168 storefront brands active since early 20...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.helpnetsecurity.com/2026/08/26/anonymousskit-phishing-stolen-iphone/>

Latest Vulnerabilities (10)

01. Ubiquiti patches 3 critical remote code execution vulnerabilities

The vulnerabilities include improper input validation in the UniFi Protect Application (CVE-2026-77537), a CRLF injection flaw in UniFi OS devices (CVE-2026-77550), and a command injection flaw in the UniFi Talk Application (CVE-2026-77554).

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/ubiquiti-patches-three-critical-remote-code-execution-vulnerabilities>

02. Critical Avada WordPress theme flaw enables zero-click RCE

A critical vulnerability chain in the popular Avada theme for WordPress can be exploited by an unauthenticated attacker to execute arbitrary PHP code on the server. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/critical-avada-wordpress-theme-flaw-enables-zero-click-rce/>

03. New GPUPhish attack defeats NVIDIA ECC protection for root access

A newly disclosed Rowhammer attack called GPUPhish can bypass error-correcting code (ECC) protections on NVIDIA GPUs, enabling denial-of-service (DoS) and root-level privilege escalation. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/new-gpuphish-attack-defeats-nvidia-ecc-protection-for-root-access/>

04. Detecting multi-stage attacks on AWS: A guide to cross-service signal correlation

A single alert from one security service tells you something happened. Read that signal alongside activity from other services and your own business context, and you will know whether what happened is part of a multi-stage attack. Consider a short sequence. An identity calls GetCallerIdentity from a source address it hasn't previously used. Within minutes,...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://aws.amazon.com/blogs/security/detecting-multi-stage-attacks-on-aws-a-guide-to-cross-service-signal-correlation/>

05. FD - Half-click unauthenticated remote code execution on Horde Groupware IMP (from a stored XSS)

Posted by Evan Tang on Aug 26 <https://blog.evan.lat/posts/CVE-2026-65053/> the blog talks about two vulns that are chainable together. for the sake of brevity ill write up on the stored xss one. in lib/Mime/Status.php, we see a pretty viable xss sink: `$out .= ' ' . $val...`

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Aug/115>

06. [NotCVE-2026-0013] CHIRP Kenwood ITM Driver Eval Injection Allows Arbitrary Code Execution via Crafted Radio File

Posted by advisories on Aug 26 -----
NotCVE Advisory - NotCVE-2026-0013

----- [-] Summary: Eval injection in the
Kenwood ITM file format driver of CHIRP, an open-source application for programming
amateur radios, allo...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into
compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for
exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Aug/114>

07. [NotCVE-2026-0012] EmpManageX Hardcoded Administrative Credentials in Login API Allow Full Access to Employee Records

Posted by advisories on Aug 26 -----
NotCVE Advisory - NotCVE-2026-0012

----- [-] Summary: kamalpanse18
EmpManageX, a Flask-based employee management application, ships hard-coded
administrative credentials in its aut...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into
compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for
exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Aug/113>

08. [NotCVE-2026-0011] Nmap 7.99 and Earlier nselib/packet.lua Zero-Length TCP Option Infinite Loop Allows Remote Denial of Service

Posted by advisories on Aug 26 -----
NotCVE Advisory - NotCVE-2026-0011

----- [-] Summary: Nmap 7.99 and
earlier contain a loop with an unreachable exit condition in the Packet:parse_options()
method of nselib/packet....

Why it matters: Exploit-ready vulnerabilities can rapidly translate into
compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for
exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Aug/112>

09. [NotCVE-2026-0010] Barrier 2.4.0 for Windows Unauthenticated IPC Command Execution Allows Local Privilege Escalation to SYSTEM

Posted by advisories on Aug 26 -----
NotCVE Advisory - NotCVE-2026-0010

----- [-] Summary: Barrier 2.4.0 for
Windows contains a local privilege escalation vulnerability in the IPC command interface
exposed by the barr...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Aug/111>

10. [NotCVE-2026-0009] NitroShare Desktop 0.3.4 Path Traversal Allows LAN-Adjacent Arbitrary File Write

Posted by advisories on Aug 26 -----

NotCVE Advisory - NotCVE-2026-0009

----- [-] Summary: NitroShare Desktop 0.3.4 contains a path traversal vulnerability in its LAN file transfer receive path. The transfer service i...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Aug/110>

Data Breach & Cybercrime (10)

01. Carhartt data breach claims inflated by synthetic data, analysis finds
ShinyHunters had claimed to leak 50GB of Carhartt's data on August 13, following a negotiation attempt after an initial extortion demand of \$3.3 million.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.scworld.com/brief/carhartt-data-breach-claims-inflated-by-synthetic-data-analysis-finds>

02. Carhartt data breach affects 12.9M, half of what ShinyHunters claimed
One AI and two trained eyes delved into the heavily padded leaks

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/08/26/carhartt-data-breach-affects-129m-half-of-wh-at-shinyhunters-claimed/5292626>

03. Interpol Operation Jackal IV Identifies 263 Cybercrime Suspects

Interpol operation leads to 58 arrests and identifies 263 suspects across 22 countries

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/interpol-operation-jackal-iv/>

04. Bogus recruiters go after high-value corporate credentials on mobile

Scammers posing as HR staff at well-known companies are running interview scheduling scams that end with a stolen corporate password, according to Zimperium. Attackers are using a technique called browser-in-the-browser, or BitB, which CTM360 documented in earlier research on recruitment phishing. They scrape public profile data and use it to craft convinci...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/08/26/recruitment-scam-corporate-passwords-mobile/>

05. [+24h Old] Beware of fake Indeed interview apps used to install spyware

Scammers are posing as employers on Indeed to trick job seekers into installing fake Android interview apps that deliver malware.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/scams/2026/08/beware-of-fake-indeed-interview-apps-used-to-install-spyware>

06. [+24h Old] INTERPOL Operation Jackal IV Arrests 58, Identifies 263 in Global Cyber Fraud Crackdown

An eight-month INTERPOL operation targeting West African organized crime groups has led to arrests of 58 people and the identification of 263 suspects. "The operation, which brought together 22 countries from six continents, is a response to the escalating global threat posed by West African criminal networks - such as the Black Axe and other similar groups...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/08/interpol-operation-jackal-iv-arrests-58.html>

07. [+24h Old] Sensitive Information Exposed in Nutex Health Data Breach

Nutex Health has informed the SEC that it recently detected unauthorized access and data exfiltration. The post Sensitive Information Exposed in Nutex Health Data Breach

appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/sensitive-information-exposed-in-nutex-health-data-breach/>

08. [+24h Old] Fake Apple Support AI Calls Target Stolen-Device Owners for Passcodes and 2FA Codes

Cybersecurity researchers have disclosed details of a phishing-as-a-service (PhaaS) platform built to strip Apple's Activation Lock from stolen devices, using rented AI voice agents that call theft victims posing as Apple Support and ask for their device passcode. SOCRadar Threat Research Unit (STRU) said the platform, which it tracks as AnonymouSkIT, is cr...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/08/fake-apple-support-ai-calls-target.html>

09. [+24h Old] LACMA data breach last year exposed social security and medical data

The Los Angeles County Museum of Art (LACMA) has announced that a breach last year exposed customer and employee information. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/lacma-data-breach-last-year-exposed-social-security-and-medical-data/>

10. [+24h Old] AnonymouSkIT PhaaS uses voice AI agents to phish iPhone passcodes

A newly uncovered phishing-as-a-service (PhaaS) platform called AnonymouSkIT automates the retrieval of codes used to unlock stolen Apple devices and disable the Activation Lock feature. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/anonymousskit-phaas-uses-voice-ai-agents-to-phish-iphone-passcodes/>